

AI Critique – HW06 API Testing

Khoa Công nghệ Thông tin (FIT) – Trường Đại học Khoa học Tự nhiên TP.HCM (HCMUS)
CS423 / CSC13003 – Kiểm thử Phần mềm (AI-augmented · 2026)

Thông tin sinh viên

Trường	Giá trị
Họ và tên:	Phan Quốc Thịnh
MSSV:	23127486
Lớp:	23KTPM3

Tổng quan số liệu Audit

API	Pool	TC AI sinh	VALID	INCOMPLETE	INVALID	TC Extend tự thêm
POST /api/register	A	42	31 (73.8%)	11 (26.2%)	0	13
GET /api/orders/my-orders	B	38	27 (71.1%)	11 (28.9%)	0	7
POST /api/admin/import-products	C	38	21 (55.3%)	17 (44.7%)	0	7
Tổng		118	79 (66.9%)	39 (33.1%)	0	27

Nhận xét phê bình AI (200–300 từ)

Sau khi kiểm tra (audit) toàn bộ 118 test cases do AI sinh ra và tự bổ sung thêm 27 TC, có thể rút ra một số nhận xét như sau:

Những điều AI làm sai hoặc bỏ sót:

AI sinh ra các test cases có cấu trúc tốt, bao phủ đầy đủ các kỹ thuật cơ bản (EP, BVA, State Transition, Security, Schema Validation), nhưng còn nhiều điểm yếu quan trọng. Thứ nhất, **expected output thường mơ hồ hoặc có điều kiện** — AI sử dụng các cụm như “400 hoặc 200 tùy rule”, “tùy hệ thống” khiến 33.1% TC bị đánh INCOMPLETE và không thể tự động hóa trực tiếp. Thứ hai, AI **không biết thông tin ngoài spec**: API `GET /api/orders/my-orders` không có pagination (xác nhận qua source code), nhưng AI lại tạo ra 6 TC kiểm tra page/limit. Tương tự, max-length của trường `name` (VARCHAR 255) không được ghi trong spec nên AI đưa ra expected mơ hồ. Thứ ba, AI **bỏ sót hoàn toàn các kịch bản nâng cao**: race condition (đăng ký đồng thời), timing attack, JWT alg:none attack, email normalization, BVA cực trên của price (integer overflow), DoS

payload, và đặc biệt là **null type** (JSON `null` khác với `""` và missing key) — một edge case mà nhiều server xử lý sai dẫn đến tạo tài khoản với password null. Thứ tư, trong phần Security, AI **áp dụng sai khái niệm**: TC-A-SEC-05 test IDOR trên public endpoint, TC-B-SEC-03 test sang endpoint khác (`/api/admin/orders` thay vì `/api/orders/my-orders`).

Tại sao AI không phát hiện ra vấn đề:

Nguyên nhân chính là **prompt chưa cung cấp đủ context**: không có source code, không có DB schema, không có policy về rate limiting hay password complexity. LLM hoạt động thuần túy dựa trên text trong prompt nên không thể suy luận các ràng buộc ẩn (implicit constraints) của hệ thống. LLM cũng không có khả năng mô hình hóa concurrent execution, timing side-channel, hay các attack vector JWT đặc thù (alg:none) nếu không được nhắc tường minh trong prompt.

Nguyên tắc học được:

Khi cộng tác với AI trong kiểm thử API, người kiểm thử cần đóng vai trò *reviewer có domain knowledge*: cung cấp spec đầy đủ kèm source code khi có thể, luôn xác minh expected output so với implementation thực tế, và tự bổ sung các kịch bản bảo mật/concurrent mà AI thường bỏ sót. AI là công cụ tăng tốc, không thay thế được tư duy kiểm thử có chiều sâu.

Tóm tắt các điểm AI làm tốt

- **Bao phủ EP/BVA cơ bản đầy đủ**: AI cô lập lỗi đúng nguyên tắc (mỗi TC chỉ sai 1 biến), phủ hầu hết các lớp tương đương hiển nhiên: empty string, missing key, wrong type, invalid format, duplicate, body rỗng.
- **State Transition Testing có hệ thống**: Xác định đúng các auth state (Unauthenticated / Authenticated / Expired) và resource lifecycle (Non-existent → Created → Active), bao gồm state sequence hợp lý (Register → Login, Import → GET products).
- **Security baseline tốt**: Phủ các attack vector phổ biến (SQL Injection, XSS, Role Escalation/Mass Assignment, Sensitive Data Exposure, Token Forgery, Expired Token, Missing Auth). TC-A-SEC-06 (role=admin mass assignment) và TC-C-SEC-02 (RBAC non-admin → 403) được sinh đúng và rõ ràng.
- **Schema Validation đủ tiêu chuẩn REST**: Kiểm tra Content-Type, HTTP status code, shape của response (field type, required fields), error response consistency — đúng theo best practice REST API testing.
- **Tốc độ sinh TC nhanh**: 118 TC được sinh từ 12 prompt (4 prompt × 3 API), tiết kiệm đáng kể thời gian so với viết thủ công hoàn toàn.

Tóm tắt các điểm AI còn hạn chế

1. Expected output mơ hồ / conditional (nguyên nhân phổ biến nhất – 33.1% INCOMPLETE)

AI thường sinh expected dạng “400 hoặc 200 tùy rule” khi không có đủ thông tin từ spec, khiến TC không thể tự động hóa. Các trường hợp điển hình:

- **Pool A**: DP-15/16 (name max-length chưa xác nhận), DP-20 (password complexity không có trong spec)
- **Pool B**: DP-08 đến DP-13 (pagination — AI suy luận có pagination nhưng thực tế API không có)

- **Pool C:** DP-03 (empty array), DP-07 (price=0), ST-07 (idempotency), ST-08 (partial failure rollback vs. partial import)

2. Không biết thông tin ngoài spec / source code

- Không biết DB column `name VARCHAR(255)` → expected BVA mở hồ (TC-A-DP-15/16)
- Không biết `GET /api/orders/my-orders` không có pagination → sinh 6 TC pagination không sử dụng được
- Không biết transaction behavior của import-products (atomic vs. partial) → TC-C-ST-08 INCOMPLETE
- Không biết schema DB đầy đủ → mass assignment chỉ test `role`, bỏ sót `is_verified`, `created_at`, `id`

3. Bỏ sót các kịch bản concurrent và timing

- **Race condition:** Đăng ký 2 request đồng thời với cùng email (Pool A – TC-A-EXT-01), Import đồng thời 2 admin (Pool C – TC-C-EXT-06)
- **Timing Attack:** Không kiểm tra response time giữa email tồn tại vs. không tồn tại (Pool A – TC-A-EXT-06)

4. Bỏ sót null type (JSON null ≠ empty string ≠ missing key)

AI test "" (empty string) và missing key cho cả 3 trường bắt buộc của Pool A, nhưng không test giá trị JSON `null`. Đặc biệt nguy hiểm với `password: null`: nếu server không validate, user có thể được tạo với password null dẫn đến bypass auth (TC-A-EXT-07/08/09).

5. Security gap: chỉ test attack vector được nhắc tên trong prompt

- **Pool A:** XSS chỉ test trường `name`, bỏ sót `email` (TC-A-EXT-12) và `password` (TC-A-EXT-13)
- **Pool B:** Không test JWT alg:none attack (TC-B-EXT-02), không test Basic auth scheme (TC-B-EXT-05)
- **Pool C:** Không test DoS với payload cực lớn > 10MB (TC-C-EXT-04), không test HTML injection trong `description` (TC-C-EXT-07)
- **Áp dụng sai khái niệm:** IDOR test trên public endpoint (TC-A-SEC-05), test endpoint khác (TC-B-SEC-03)

6. Bỏ sót edge cases email format

- Email thiếu local-part (`@domain.com`) — AI test thiếu `@` và thiếu domain nhưng bỏ trường hợp đối xứng (TC-A-EXT-11)
- Email plus-addressing (`user+tag@domain.com`) — không test định dạng hợp lệ theo RFC 5321 (TC-A-EXT-05)
- Email case normalization (`TEST@domain.com` vs `test@domain.com`) — không test policy case-insensitive (TC-A-EXT-02)

7. Không test BVA cực trên (numeric overflow)

- `price = 999999999999` cho Pool C — AI test BVA phía dưới (0, -1) nhưng không test cực trên (TC-C-EXT-03)
- Giá trị rất lớn có thể gây integer overflow hoặc bị truncate silently trong DB (DECIMAL precision)

Bài học rút ra khi cộng tác với AI

- 1. **Cung cấp context đầy đủ = AI cho output tốt hơn đáng kể.** Khi prompt bao gồm source code, DB schema, và business rules rõ ràng (ví dụ: "min password = 8", "API không có pagination"), tỷ lệ INCOMPLETE giảm mạnh và expected output có thể tự động hóa ngay mà không cần sửa.
- 2. **AI giỏi sinh TC đơn lẻ trong luồng chính, yếu với kịch bản hệ thống.** EP/BVA cơ bản, auth states, schema validation — AI làm tốt. Nhưng race condition, timing attack, JWT-specific vulnerabilities, null type edge cases, DoS — những kịch bản đòi hỏi hiểu biết về system internals và threat modeling — AI bỏ sót nếu không được nhắc tưởng mình.
- 3. **Luôn audit và verify expected output so với implementation thực tế.** Bước audit thủ công là bắt buộc: đọc source code, đọc spec gốc, kiểm tra DB schema để xác nhận boundary conditions trước khi đưa TC vào collection Newman. Đây là bước con người không thể bỏ qua dù AI sinh output có vẻ đúng.
- 4. **AI là công cụ tăng tốc, không thay thế domain knowledge.** 27 TC tự thêm (Extend) — bao gồm các kịch bản security nâng cao, null type, concurrent, BVA cực trên, Unicode — chỉ có thể được xác định bởi người kiểm thử có kinh nghiệm. AI đóng vai trò "junior tester" tự động hóa phần cơ bản; review và bổ sung là trách nhiệm của con người.
- 5. **Phân loại lý do AI bỏ sót giúp cải thiện prompt engineering cho lần sau.** Phần lớn thiếu sót xuất phát từ: (a) prompt chưa cung cấp đủ spec/context, (b) model limitation về concurrent/timing/attack-vectors, (c) attack vectors không được đặt tên trong prompt. Hiểu rõ từng loại nguyên nhân giúp thiết kế prompt chính xác hơn trong các dự án tiếp theo.

Phân tích chi tiết theo từng Pool

Pool A – POST /api/register

Hạng mục	Chi tiết
Tổng TC	42 AI sinh + 13 Extend = 55 TC
Điểm mạnh	Cô lập lỗi EP tốt; xác định đúng 3 trường bắt buộc; security patterns phổ biến (SQLi, XSS, Role Escalation) đủ; State Transition đúng lifecycle
Điểm yếu	BVA password ban đầu sai min (giả định 6, sửa thành 8 sau xác nhận spec); IDOR test sai khái niệm trên public endpoint; bỏ sót null type (3 TC), email local-part missing, XSS vào email/password, race condition, timing attack
TC INCOMPLETE nổi bật	DP-15/16 (name max-length), DP-20 (password complexity policy), SEC-05 (IDOR sai), SEC-07 (rate limit policy chưa xác nhận)
TC Extend đáng chú ý	EXT-07/08/09 (null type cho email/name/password), EXT-11 (@domain.com), EXT-12/13 (XSS email/password), EXT-06 (timing attack), EXT-10 (BVA 256 ký tự)

Pool B – GET /api/orders/my-orders

Hạng mục	Chi tiết
----------	----------

Hạng mục	Chi tiết
Tổng TC	38 AI sinh + 7 Extend = 45 TC
Điểm mạnh	Auth state transitions đầy đủ; IDOR qua query param (user_id); data exposure check; business states (pending/confirmed/canceled/delivered/shipping) đều có TC
Điểm yếu	6 TC pagination (DP-08~13) INCOMPLETE vì API không có pagination; SEC-03 test sang endpoint sai; SQL injection expected mơ hồ
Phát hiện quan trọng	Xác nhận qua <code>backend/server.js</code> : API không implement pagination — tất cả query params bị ignore, luôn trả toàn bộ orders của user từ token
TC Extend đáng chú ý	EXT-01 (cross-user data isolation), EXT-02 (JWT alg:none), EXT-03 (ordering DESC), EXT-04 (nested schema shipping_address), EXT-05 (Basic auth scheme), EXT-07 (full enum coverage)

Pool C – POST /api/admin/import-products

Hạng mục	Chi tiết
Tổng TC	38 AI sinh + 7 Extend = 45 TC
Điểm mạnh	RBAC enforcement (401/403) đầy đủ; Domain partition cô lập tốt (name rỗng, price âm, FK không tồn tại, type mismatch); Schema validation error response nhất quán
Điểm yếu	Tỷ lệ INCOMPLETE cao nhất (44.7%) — nhiều business rule chưa rõ trong spec: empty array, price=0, batch size limit, transaction behavior
TC INCOMPLETE nổi bật	ST-07 (idempotency: tạo thêm hay reject?), ST-08 (partial failure: rollback hay 207?), SEC-03 (IDOR concept không đúng), SEC-04/05 (SQLi expected mơ hồ), SEC-08 (XSS expected mơ hồ)
TC Extend đáng chú ý	EXT-01 (intra-batch duplicate name), EXT-02 (mass assignment id/created_at), EXT-03 (price 9999999999999999999 overflow), EXT-04 (DoS >10MB), EXT-05 (Unicode/emoji), EXT-07 (HTML injection in description)